

CAPACITACIÓN, CONCIENTIZACIÓN Y ENTRENAMIENTO

BY NOVA TECH SOLUTIONS

1. INTRODUCCIÓN DEL PROGRAMA DE CAPACITACIÓN

Este documento establece un programa de capacitación, concientización y entrenamiento destinado a todos los contribuidores dentro de NovaTech Solutions, con el propósito de modificar positivamente los hábitos mediante la educación, permitiendo la identificación de riesgos, dónde residen y cómo mitigarlos.

Dentro del programa se abarcan conceptos de Seguridad de la Información, políticas internas de seguridad, leyes aplicables, buenas prácticas de seguridad, simulacros y respuesta a incidentes con el objetivo de desarrollar y evaluar la capacidad analítica de los empleados.

2. CONTENIDOS

Como parte principal del programa se establece un curso de capacitación, donde se enseñan los siguientes temas relevantes:

1. Marco normativo y legal
 - Normas, leyes y estándares establecidos en el Marco de referencia del SGSI
 - Buenas prácticas de seguridad.
 - Consecuencias legales y sanciones por incumplimiento.
2. Políticas internas de seguridad
 - Uso aceptable de sistemas y redes.
 - Contraseñas y autenticación (MFA, requisitos mínimos).
 - Protección de datos y privacidad.
 - Control de acceso físico y lógico.
 - Uso de correo electrónico y navegación web.
 - BYOD y gestión de dispositivos personales.
 - Actualizaciones y parches de seguridad.
 - Copias de seguridad (backups).
 - Uso responsable de inteligencia artificial.
3. Gestión de incidentes
 - Definición de incidente de seguridad.
 - Procedimiento de reporte y escalamiento.
 - Roles y responsabilidades del equipo de respuesta.
 - Simulacros de ataques (phishing, ransomware).
4. Protección de datos y privacidad
 - Clasificación de datos (personales, financieros, propiedad intelectual).

- Cifrado y almacenamiento seguro.
 - Avisos de privacidad en plataformas digitales.
 - Derechos de los titulares de datos (ARCO: acceso, rectificación, cancelación, oposición).
5. Buenas prácticas de seguridad
- Creación de contraseñas seguras.
 - Identificación de correos de phishing.
 - Navegación segura en internet.
 - Uso correcto de dispositivos personales en entornos corporativos.
6. Cultura organizacional
- Concientización sobre la importancia de la seguridad.
 - Responsabilidad individual de cada empleado.
 - Ejemplos prácticos de cómo las políticas protegen a la empresa y a los clientes.
7. Monitoreo y auditoría
- Cómo se revisa el cumplimiento de políticas.
 - Importancia de los logs y registros de acceso.
 - Auditorías internas y externas.

CAPACITACIÓN MODULARIZADA: El desarrollo del curso se encuentra seccionado en 7 módulos de aprendizaje, diseñados para lograr una visión integral de los temas.

Módulo 1: Marco normativo y fundamentos del SGSI

- Introducción al SGSI.
- Obligaciones legales en México y sanciones por incumplimiento.
- Principios de seguridad de la información: confidencialidad, integridad, disponibilidad.

Módulo 2: Políticas internas de seguridad

- Uso aceptable de sistemas y redes.
- Contraseñas y autenticación (MFA, requisitos mínimos).
- Protección de datos y privacidad.
- Control de acceso físico y lógico.
- Uso de correo electrónico y navegación web.
- BYOD y gestión de dispositivos personales.
- Actualizaciones y parches de seguridad.

- Copias de seguridad (backups).
- Uso responsable de inteligencia artificial.

Módulo 3: Gestión de incidentes de seguridad ●

Definición y clasificación de incidentes.

- Procedimiento de reporte y escalamiento.
- Roles y responsabilidades del equipo de respuesta.
- Simulacros de ataques (phishing, ransomware, fuga de datos).

Módulo 4: Protección de datos y privacidad

- Clasificación de datos (personales, financieros, propiedad intelectual).
- Cifrado y almacenamiento seguro.
- Avisos de privacidad en plataformas digitales.
- Derechos ARCO (Acceso, Rectificación, Cancelación, Oposición).

Módulo 5: Buenas prácticas de seguridad

- Creación y gestión de contraseñas seguras.
- Identificación de correos de phishing y sitios maliciosos.
- Navegación segura en internet.
- Uso correcto de dispositivos personales en entornos corporativos.

Módulo 6: Cultura organizacional y concientización

- Responsabilidad individual de cada empleado en la seguridad.
- Ejemplos prácticos de cómo las políticas protegen a la empresa y a los clientes.

Módulo 7: Monitoreo y auditoría ●

Logs y registros de acceso.

- Auditorías internas y externas.
- Reportes de cumplimiento para dirección y clientes estratégicos.

3. FRECUENCIA

Duración total: 24 horas (repartidas en 6 módulos de 4 horas cada uno) ●

Modalidad: híbrida (presencial + virtual).

- Frecuencia: 2 sesiones por semana, durante 3 semanas.
- Participantes: todo el personal con acceso a sistemas, datos o infraestructura crítica.

El curso completo es enseñado una vez al año, aun así, con el objetivo de fomentar la retención de los conocimientos obtenidos, se continúan aplicando actividades y simulaciones mensuales. Estos refuerzos periódicos también ayudan a recopilar métricas de comportamiento, que serán analizadas para conocer la efectividad del programa.

Tipo de actividad	Frecuencia	Duración
Curso completo	Anual	24 horas totales
Refuerzo del curso	Trimestral	8 horas
Simulaciones	Mensual	2 horas
Talleres prácticos	Mensual	2 horas
Refuerzos especializados (para empleados que fallen en simulaciones)	Mensual	2 horas
Cápsulas informativas	Mensual	1 hora
Correos con alertas/consejos	Semanal	-

4. MÉTODOS

El curso se compone de clases teóricas, actividades, simulaciones y ejercicios diseñados para que cualquier empleado pueda aprender los fundamentos y aplicarlos. En conjunto proporcionan una experiencia amena que facilita la retención de información.

Módulo 1: Marco normativo y fundamentos del SGSI (4h)

- **Objetivo:** Comprender Normas, leyes y estándares establecidos en el Marco de referencia del SGSI.
- **Actividades:**
 - Exposición teórica con ejemplos de sanciones en México.
 - Debate sobre riesgos legales en PyMEs.
 - Evaluación rápida tipo quiz.

Módulo 2: Políticas internas de seguridad (4h)

- **Objetivo:** Conocer y aplicar las políticas internas de NovaTech.
- **Actividades:**
 - Taller práctico de creación de contraseñas seguras.
 - Simulación de acceso controlado a sistemas.
 - Ejercicio de clasificación de datos sensibles.

Módulo 3: Gestión de incidentes de seguridad (4h)

- **Objetivo:** Saber cómo detectar, reportar y responder a incidentes.
- **Actividades:**
 - Simular un reporte de incidente.
 - Simulacro de ataque de phishing y ransomware.
 - Elaboración de bitácora de incidentes.

Módulo 4: Protección de datos y privacidad (4h)

- **Objetivo:** Garantizar el cumplimiento de la LFPDPPP y derechos ARCO.
- **Actividades:**
 - Ejercicio de redacción de aviso de privacidad.
 - Taller de cifrado básico de archivos.
 - Caso práctico: solicitud de acceso de un cliente a sus datos.

Módulo 5: Buenas prácticas de seguridad (4h)

- **Objetivo:** Adoptar hábitos seguros en correo, navegación y BYOD.
- **Actividades:**
 - Simulación de detección de correo de phishing.
 - Navegación segura con proxy/firewall.
 - Configuración de seguridad en dispositivos personales.

Módulo 6: Cultura organizacional, monitoreo y auditoría (4h)

- **Objetivo:** Fomentar la responsabilidad individual y el cumplimiento continuo.
- **Actividades:**
 - Dinámica grupal sobre responsabilidad compartida.
 - Ejemplo práctico de revisión de logs de acceso.
 - Auditoría simulada con checklist de cumplimiento.

Requisitos previos para el curso SGSI

Para la correcta aplicación del curso se requieren los siguientes materiales y servicios, el presupuesto para los mismos deberá ser aprobado por la dirección general:

1. Infraestructura

- **Aula física o sala virtual** equipada con proyector, pizarrón digital o plataforma de videoconferencia (Teams/Zoom).
- **Acceso a internet seguro** y estable para simulaciones en línea.
- **Laboratorio de pruebas** con equipos configurados para ejercicios prácticos (ej. creación de contraseñas, simulacros de incidentes).

2. Software y herramientas

- Plataforma de **gestión de aprendizaje (LMS)** para registrar asistencia, evaluaciones y materiales.
- Herramientas de seguridad: antivirus corporativo, firewall, SIEM para simulaciones.
- Aplicaciones de cifrado y gestión de contraseñas (ej. BitLocker, KeePass).
- Simuladores de phishing y ransomware para prácticas controladas.

3. Materiales de capacitación

- Manual del curso con todas las políticas internas (uso aceptable, contraseñas, privacidad, incidentes, backups, IA, etc.).
- Guías rápidas (checklists) para cada política.
- Ejemplos de avisos de privacidad y bitácoras de incidentes.
- Presentaciones y casos prácticos adaptados al giro de NovaTech.

4. Instructores y roles

- **Instructor principal:** experto en SGSI e ISO 27001.
- **Especialista legal:** para explicar la LFPDPPP y sanciones.
- **Equipo de TI interno:** apoyo en simulaciones técnicas.
- **Responsable de datos personales:** para casos prácticos de privacidad y derechos ARCO.

5. Participantes

- Todo el personal con acceso a sistemas, datos o infraestructura crítica.
- Clasificación por roles: desarrolladores, soporte, administración, dirección.
- Compromiso de asistencia completa y participación en simulacros.

6. Evaluación y certificación interna

- Examen teórico (marco legal y políticas).
- Examen práctico (simulación de incidente).
- Constancia interna de cumplimiento SGSI para cada participante

5. EVALUACIÓN

Al finalizar el curso, se aplicarán exámenes para evaluar la eficacia del curso y se otorgarán certificaciones.

- **Examen práctico:** simulación de un incidente real (ej. fuga de datos).
- **Examen teórico:** preguntas sobre políticas y marco legal.
- **Certificación interna:** constancia de participación y cumplimiento SGSI.

A partir de las métricas de comportamiento obtenidas en los refuerzos periódicos de actividades, se realizan análisis de frecuencias para determinar con exactitud el nivel de desempeño del programa.

Adicionalmente se realizarán encuestas de satisfacción de forma posterior al curso, esto para conocer la opinión de los empleados y buscar áreas de mejora.

El programa apunta a las siguientes estadísticas:

- Tasa de finalización: Un 90% o más, indicador de que los empleados están comprometidos y que el material es accesible.
- Satisfacción (NPS): Una puntuación superior a 45 en encuestas de satisfacción.
- Impacto en la retención: Que el 92% de los empleados tenga un mayor compromiso con su empresa.

Se realizarán los cambios necesarios al programa para alcanzar las estadísticas deseadas si el análisis de los datos muestra poco éxito del curso.